

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 1 頁，共 12 頁

單選題 50 題（佔 100%）

C	1. 有關阻斷服務攻擊（DoS 攻擊）之敘述，下列何者正確？ (A) 攻擊者偽造傳輸層封包來破壞網路的攻擊行為 (B) 攻擊者使用惡意軟體在設備上執行未經授權的攻擊行為 (C) 攻擊者向目標伺服器發送大量請求，使其無法處理其他請求的攻擊行為 (D) 攻擊者使用偽造的電子郵件來詐騙用戶的攻擊行為
B	2. 下列何項行為最容易導致 OWASP Top 10 的 A01:2021-Broken Access Control 漏洞發生？ (A) 使用強密碼進行身份驗證 (B) 未在頁面上實施權限控制 (C) 在密碼重置流程中使用多重身份驗證 (D) 定期進行安全漏洞掃描與修復
B	3. 隨著無線網路盛行，在伺服器與客戶端之間放置雙方都無法察覺的軟體進行攔截、備份、竄改資料等動作會再傳送給接收方的是下列何種攻擊手法？ (A) 重放攻擊 (B) 中間人攻擊 (C) 網路釣魚 (D) 社交工程
A	4. 校園網路屬於下列何種網路類型？ (A) 區域網路（Local area network，LAN） (B) 廣域網路（Wide Area Network，WAN） (C) 網際網路（Internet） (D) 個人區域網路（Personal Area Network，PAN）
A	5. 在 OSI（Open System Interconnection Model）的參考模型中，諸如 Chrome、Firefox 等瀏覽器軟體應該屬於下列何項層次？ (A) 應用層（Application Layer）

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 2 頁，共 12 頁

	(B) 網路層 (Network Layer) (C) 資料連結層 (Data Link Layer) (D) 傳輸層 (Transport Layer)
C	6. 下列何項網路設備可以找出傳送封包的最佳路徑？ (A) 中繼器 (B) 橋接器 (C) 路由器 (D) 集線器
D	7. 請問 DNS 放大攻擊 (DNS Amplification Attacks)，最屬於下列何種網路攻擊？ (A) 病毒 (B) 木馬 (C) 蠕蟲 (D) 阻斷服務攻擊
C	8. 建置虛擬私有網路 (Virtual Private Network, VPN) 的主要目的是下列何項？ (A) 加速網路連接，增加下載檔案的速度 (B) 增加網站流量，創造瀏覽次數 (C) 保護網路傳輸的資料安全 (D) 阻擋廣告，避免廣告消耗網路頻寬
A	9. 關於通訊埠 (Port) 預設端口的敘述，下列何項錯誤？ (A) SFTP，通訊埠 21 (B) RDP 為遠端桌面，通訊埠 3389 (C) HTTP，通訊埠 80 (D) DNS，通訊埠 53
A	10. 有關防火牆進行封包過濾時所考慮之因素，下列描述何者最「不」適切？ (A) 僅考慮封包的目的位址 (B) 封包的協定 (C) 封包的連接埠編號

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 3 頁，共 12 頁

	(D) 封包的網路界面
B	11. 有關 TCP/IP (DoD) 模型之敘述，下列何者有誤？ (A) 包含應用層 (Application Layer) (B) 包含會談層 (Session Layer) (C) 包含網際網路層 (Internet Layer) (D) 包含網路存取層 (Network Access Layer)
C	12. 當企業有大量的內部網址時，會自行架設 DNS Server，如果 DNS Server 的需求量較高，可能需要建置多台 DNS Server 互相備援，並且使用一個特定功能來傳輸各台 DNS Server 彼此的 DNS Record，讓每一台 DNS Server 的紀錄都保持一致。但是如果該功能沒有限制存取來源，可能會導致任意使用者都可以透過該功能直接跟企業的 DNS Server 索取該企業全部的 DNS Record，造成內部的網址外流。請問下列何項就是上述的特定功能？ (A) DNS Tunneling (B) DNS Amplification (C) DNS Zone Transfer (D) DNS Spoofing
A	13. 下列哪一個通訊協定沒有經過加密傳輸，直接採用明文的方式傳輸，有機會被攻擊者竊聽？ (A) TELNET (B) FTPS (C) HTTPS (D) SSH
A	14. 下列何者可以用來評估作業系統 (Operation system) 的安全性最為適切？ (A) Common Criteria (B) ISO/IEC 27001 (C) IEC 62443-2-1 (D) Cybersecurity Framework
B	15. 關於 Rootkit 和 Bootkit 的敘述，下列何項最「不」適切？ (A) Rootkit 是一種惡意軟體，用於隱藏攻擊者對操作系

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 4 頁，共 12 頁

	統的控制權 (B) Rootkit 的偵測防禦容易，因為它易被防毒軟體發現 (C) Bootkit 是一種惡意軟體，與 Rootkit 類似，但是它是安裝在操作系統的引導（boot）區塊，以實現在操作系統啟動之前攻擊的目的 (D) 與 Rootkit 一樣 Bootkit 可以隱藏攻擊者的存在和攻擊行為，例如隱藏進程、檔案、目錄、登錄項目、網路連接等等，從而繼續控制和攻擊受害者系統
B	16. 常見作業系統安全管理，下列何項敘述是錯誤的？ (A) 導入政府組態基準（Government Configuration Baseline, GCB）強化作業系統安全 (B) Administrator 帳戶建議開啟 (C) Guest 帳戶建議停用 (D) 建議設定帳戶鎖定閾值（嘗試登入錯誤次數）：5 次以下不正確的登入嘗試，但須大於 0 次
D	17. 在攻擊者已經取得系統存取權限之後，除了翻找系統有沒有高權限帳號的密碼或是嘗試破解雜湊之外，也可能會利用已知的提升權限弱點來讓自己變成 root 或 Administrator，以便取得更完整的系統控制權。請問下列何項「不」是 Windows 或 Linux 作業系統常見用來提升權限的弱點或技巧？ (A) Dirty COW (B) SetUID (C) Juicy Potato (D) Chisel
B	18. 下列何者是微軟網路芳鄰會使用到的 port？ (A) TCP 248 (B) TCP 445 (C) TCP 80 (D) TCP 20
D	19. 關於 SQL Injection 攻擊及其防範的敘述，下列何者錯誤？ (A) SQL Injection 攻擊主要是利用應用程式撰寫上的疏

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 5 頁，共 12 頁

	忽，使得執行非預期的 SQL 指令，非法存取資料庫中的內容 (B) SQL Injection 攻擊所採用之攻擊方法，是一種利用未做好輸入查驗（Input Validation）所衍生的問題 (C) 發生 SQL Injection 攻擊最大的原因，在於未對輸入文字進行過濾，未作完善的輸入條件檢查 (D) 關於 SQL Injection 攻擊之預防拒絕輸入單引號、雙引號、分號等特殊字元即可
A	20. 為避免資料庫被入侵攻擊，下列何種處理方式最適合？ (A) 應用系統採用多因素身份驗證機制進行設計，可確保應用程式對資料庫存取身分 (B) 不用定期更新資料庫軟體版本，因為會影響程式相容性 (C) 資料庫中的敏感資料不用加密，以提升效能 (D) 資料庫多在內網，十分安全不需監視資料庫活動
D	21. 下列何種攻擊手法是透過瀏覽器執行攻擊者插入到網頁中的 Script 指令，來竊取使用者輸入的資料？ (A) 緩衝區溢位攻擊（Buffer Overflow） (B) 釣魚攻擊（Phishing） (C) 阻斷服務攻擊（DoS） (D) XSS 攻擊（Cross-Site Scripting）
C	22. 依據 OWASP Top 10 有關應用程式未驗證或過濾使用者所提供資料而產生風險之敘述，下列何者有誤？ (A) 常見的攻擊手法包含 Cross-site Scripting 攻擊 (B) 常見的攻擊手法包含 SQL Injection 攻擊 (C) 需要將命令與查詢資料合併，以防止注入式攻擊 (D) 屬 OWASP Top 10 的 Injection 風險
B	23. 在 IP camera 使用時，要做下列何項串流的安全傳輸協定以避免攻擊？ (A) SMTPS

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 6 頁，共 12 頁

	(B) RTSPS (C) SFTP (D) RDP
C	24. 網站應用程式中的元件存在弱點，若要有效避免遭受攻擊者利用的改善措施，下列何者錯誤？ (A) 移除不必要的元件、功能或檔案 (B) 持續盤點用戶端與伺服器端元件的版本，並確認是否含有漏洞 (C) 僅從官方網站與知名論壇取得相關元件 (D) 監控已無維護的元件，可透過虛擬修補（Virtual Patch）降低受駭風險
D	25. 關於安全的實做密碼重設功能的敘述，下列何者錯誤？ (A) 避免使用密碼問題來確認為其為本人 (B) 不可儲存使用者重新設定之密碼明文 (C) 密碼重設後，應自動登出該帳號既有連線 (D) 應發送通知並附上密碼供本人確認修改內容
C	26. 關於應用程式安全的描述，下列何者最「不」適切？ (A) 應用程式弱點掃描可以瞭解是不是有既有的技術性弱點 (B) 應用程式碼的掃描可及早偵測程式撰寫的問題及可能產生的安全性問題 (C) 模糊測試（Fuzzing）指自動產生程式碼到原始程式中，以偵測程式碼的問題 (D) 應用程式的業務邏輯問題需要由熟悉業務的測試人員仔細的核實確認
C	27. 下列何項「不」是程式碼開發所使用的原始碼檢測工具（Static Code Analysis，SCA）？ (A) Fortify (B) Checkmarx (C) Nessus (D) SonarQube

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 7 頁，共 12 頁

D	28. 下列何項「不」是 C 程式語言常見的漏洞？ (A) Buffer Overflows (B) String Manipulation (C) Integer Overflow (D) SQL Injection
A	29. 下列何者「不」是用在分析了解惡意程式或作為弱點管理的服務及工具？ (A) archive.org (B) VirusTotal (C) ANY.RUN (D) vx-underground.org
B	30. 當上網時，防毒軟體跳出提示告知不明的項目，你不知道軟體來源，但又怕誤刪重要的檔案，請問應該優先採取下列何項的處理方式？ (A) 允許執行 (B) 隔離可疑項目 (C) 移除可疑項目 (D) 更新病毒碼
A	31. 下列何種惡意程式可以自己存在不需要寄生在其他的程式與檔案中，而且可以自己複製、自行在網路上傳播？ (A) 蠕蟲 (B) 木馬 (C) 邏輯炸彈 (D) 病毒
A	32. 面對勒索軟體檔案加密的威脅，業界採用多重備份來事前預防。關於業界常用的「3-2-1 備份原則」的描述，下列何正確？ (A) 3 是指三份備份、2 是指兩種不同儲存媒體、1 是指一份異地保存 (B) 3 是指三個單位核准、2 是指兩個主管確認、1 是指一個人員備份

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 8 頁，共 12 頁

	(C) 3 是指三級單位執行、2 是指二級單位確認、1 是指一級單位稽核 (D) 3 是指三種備份技術、2 是指二種備份流程、1 是指一個備份人員
C	33. 與防範惡意軟體有關議題，下列何項描述最「不」適切？ (A) 教育訓練所有的使用者對惡意軟體的基本知識，是最重要的防範方式 (B) 單純安裝惡意程式偵測軟體，通常不足以防範，系統存取權限與變更管理流程亦需加強 (C) 於作業系統中安裝應用程式的管理，黑名單比白名單的授權方式，對系統管理者更為有效 (D) 公司內網存取的實作控制措施，白名單的管控對預防惡意網站的攔阻更為有效
D	34. 關於數位版權管理（Digital rights management，DRM）的敘述，下列何者最「不」適切？ (A) DRM 是資料保護的一種方法 (B) DRM 是一系列存取控制技術，通常用於控制數位內容和裝置在被銷售之後的使用過程 (C) DRM 可控制使用者存取裝置和使用內容的方式 (D) NFT 技術可相容於現有所有的 DRM 技術
D	35. 如附圖所示，分析圖中非明文字串，所使用的加密、雜湊或編碼方式，下列敘述何項正確？ SG93IGRvIHlvdSBlbmNvZGUgb3lgZGVjb2RIIGJhc2U2NCBzdHJpbmc/Cg== (A) SHA3 (B) NetNTLMv2 (C) AES-128 (D) Base64
C	36. 關於資料備份流程的描述，下列何項正確？ (A) 資料備份於同機房其他設備保留一份，即可滿足備

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 9 頁，共 12 頁

	份要求 (B) 工具排程備份若有失敗狀況，因為隔天還會進行，不需要手動重新備份 (C) 備份結果須於可回復的設備，定期進行完整還原測試 (D) 依照內部提供的容量資源，決定保留代數
D	37. 關於系統通行碼管理的描述，下列何項最「不」適切？ (A) 應用系統通行碼選用，不應以鍵盤字母排列方式進行 (B) 通行碼於原始碼或資料庫中顯示，皆不適以明碼方式儲存 (C) 於資訊安全事故發生後，系統通行碼應於必要時要求強制變更 (D) 為了資訊安全上考量，通行碼長度應越短越適宜
D	38. 某公司於每日的凌晨 1 點進行備分，每週日進行完整備份（Full Backup），其餘各日進行增量備份（Incremental Backup），假設需要還原至週三下班時的狀況，需要下列何項備份檔案才能完成這樣工作？ (A) 該週日的備份即可 (B) 該週三的備份即可 (C) 該週日、一、二、三等 4 份的備份檔案 (D) 該週日、一、二、三、四等 5 份的備份檔案
C	39. 關於安全性資訊與事件管理（SIEM）的敘述，下列何者較「不」適切？ (A) SIEM 結合了安全相關的資訊管理及事件管理 (B) SIEM 用途包含偵測攻擊 (C) SIEM 不會有誤報與誤判的問題 (D) SIEM 側重於日誌的集中式管理和審計
C	40. 公司的官網受到駭客入侵，必須從官網 IIS Log File 來追蹤駭客來源以及手法，關於 IIS Log File 的敘述，下列何者錯誤？ (A) IIS 預設 log 路徑為

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 10 頁，共 12 頁

	%SystemDrive%\inetpub\logs\LogFiles\ (B) IIS 如果有多個網站 網站的 log 會在資料夾中以 u_exyymmdd.log 的 log 檔呈現 (C) 在預設狀態下，IIS 預設的日誌時間與台灣時間是一致的 (D) IIS 提供了 4 種日誌檔格式 (1) IIS 紀錄檔格式、 (2) NCSA 紀錄檔案格式、(3) W3C 紀錄檔格式、 (4) 自定義日誌檔案格式
D	41. 入侵偵測與防禦系統 (Intrusion Detection and Prevention Systems, IDPS) 可以主動反應偵測到的威脅，下列敘述何項最「不」適切？ (A) 發出入侵警告訊息 (B) 記錄入侵事件 (C) 可即時阻擋所偵測到的威脅 (D) 將入侵者引導到 DMZ (Demilitarized Zone) 區
B	42. 下列何項為應用系統日誌管理的主要目的？ (A) 加速系統的運作 (B) 用於故障排除、合規性記錄、支援威脅檢測、安全性問題確認等目的 (C) 監控系統用戶的操作 (D) 監督系統運用的效能
C	43. 某系統管理員查看一 RFC 5424 協定的記錄時，其 PRI (Priority Value) 為 165，請問下列個描述較為正確？ (A) Facility 可能是 kernel messages (B) Facility 可能是 NTP subsystem (C) Facility 可能是 local use x (D) Severity 可能是 Emergency: system is unusable
D	44. 依照雲端運算聯盟 (Cloud Security Alliance, CSA) 於 2019 年 8 月發表雲端運算面臨十一大安全威脅報告中，請問沒有使用強密碼是下列何種安全威脅？

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 11 頁，共 12 頁

	(A) 資料外洩 (Data Breaches) (B) 配置錯誤和變更控制不足 (Misconfiguration and inadequate change control) (C) 缺乏雲端安全架構和策略 (Lack of cloud security architecture and strategy) (D) 驗證密碼控制機制不足 (Insufficient identity, credential, access and key management)
D	45. 依照雲端運算聯盟 (Cloud Security Alliance, CSA) 發表的「雲端運算關鍵領域安全指南」，下列針對雲端運算的安全問題的敘述何者錯誤？ (A) 資料外洩是雲端運算安全的重大威脅，像是蘋果 iCloud 用戶洩密事件 (B) 資料遺失影響企業與客戶間的信任關係 (C) 安全性差的 API 會讓企業面臨機密性、完整性、可用性和歸責性的安全問題 (D) 雲端服務的安全防禦部署分散，若服務遭受攻擊不會影響整體環境
A	46. 行動裝置特別重視資料保護，下列敘述何者錯誤？ (A) 使用行動裝置雲端服務 (如：Google Drive、iCloud...等)，是大型雲端服務公司安全有其保障，可將資料傳送到雲端空間 (B) 廢棄行動裝置，應完整清除其上所有資料，並回復為行動裝置之出廠設定 (C) 不使用藍芽功能以進行無線耳機、無線鍵盤或檔案傳輸連結時，應將其關閉 (D) 不使用 NFC 功能，應將其關閉或遮蔽
C	47. 依照歐盟網路安全局 (European Union Agency for Cybersecurity, ENISA) 所發佈關於智慧型手機的十二項安全風險，請問透過偽造的 Apps、簡訊 Mail，藉以騙取使用者的密碼是下列何項？

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 12 頁，共 12 頁

	(A) 網路雍塞 (Network Congestion) (B) 資料外洩 (Data Leakage) (C) 釣魚行為 (Phishing) (D) 自動撥號 (Automatic Dialing)
C	48. 關於行動裝置的安全保護措施，下列敘述何者錯誤？ (A) 軟體下載與使用應該檢視權限的要求，確保沒有資料外洩的風險 (B) 軟體應自動或定期手動安裝更新修補程式 (C) 資安威脅不會影響行動裝置的電池壽命 (D) 行動裝置管理系統 (Mobile Device Management, MDM) 會限制行動裝置的行為，甚至可以遠端變更與清除行動裝置的內容
A	49. 知名的 Mirai 惡意程式針對物聯網設備進行感染後，可透過攻擊者控制發動 DDoS，請問主要是下列何項原因造成物聯網設備被感染？ (A) 預設的設定與密碼 (B) 低運算力 (C) 設備量大 (D) 持續連網
A	50. 關於物聯網的資安指引必須確立物聯網的裝置、系統、服務提供的安全性。相較一般 IT 設備，對於物聯網的設備描述何者「不」正確？ (A) 物聯網的設備牽扯隱私或是人身安全的要求比較不敏感 (B) 物聯網的軟硬體設備資源較缺乏且受限制 (C) 物聯網的設備缺乏穩定且有效的機制，且受限於硬體必須執行輕量化的演算法 (D) 物聯網的設備數量龐大且異質化的系統導致安全性不易維持